Information Assurance and Security – ACIT4630

Iman Anooshehpour
Week 13

BRITISH COLUMBIA
INSTITUTE TECHNOLOGY

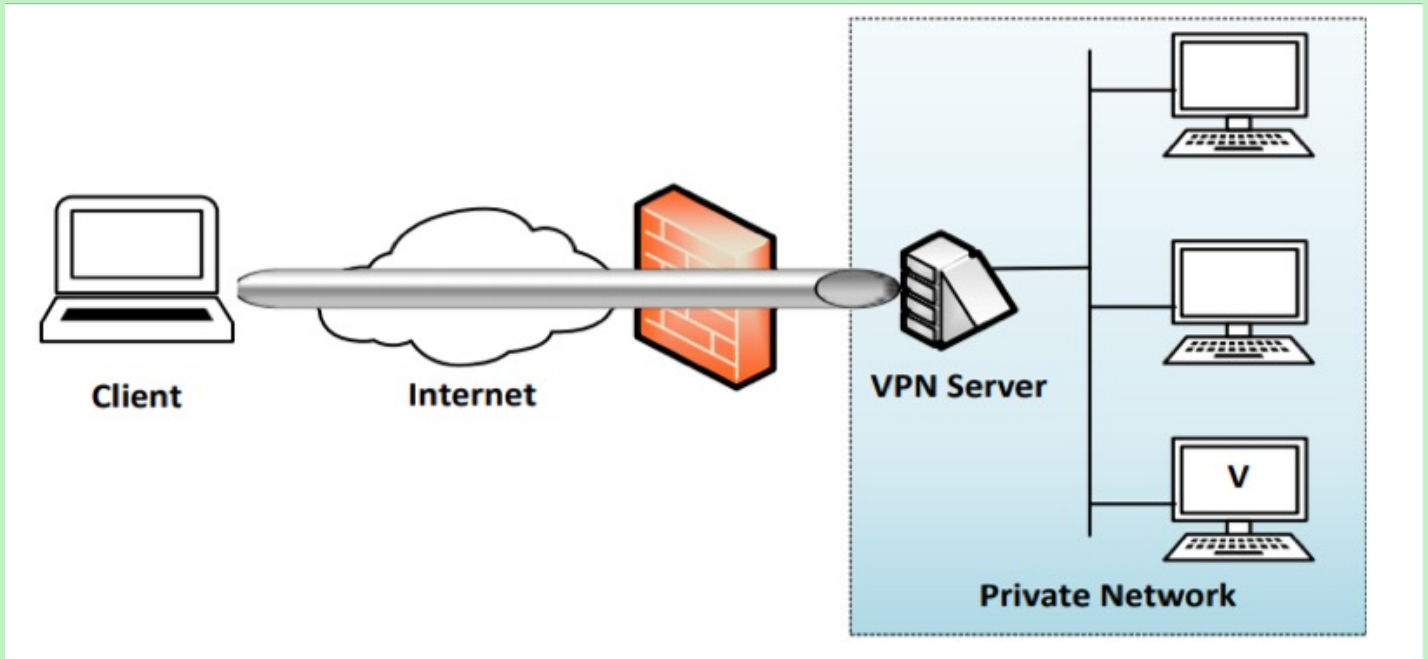
BCIT™

Learning Objectives

- ❑ Explain use-cases of VPN and how VPN could be used to bypass a firewall
- ❑ Explain DNS query process and its attack surface
- ❑ Describe different DNS attacks
- ❑ Carry out DNS spoofing attacks in the lab

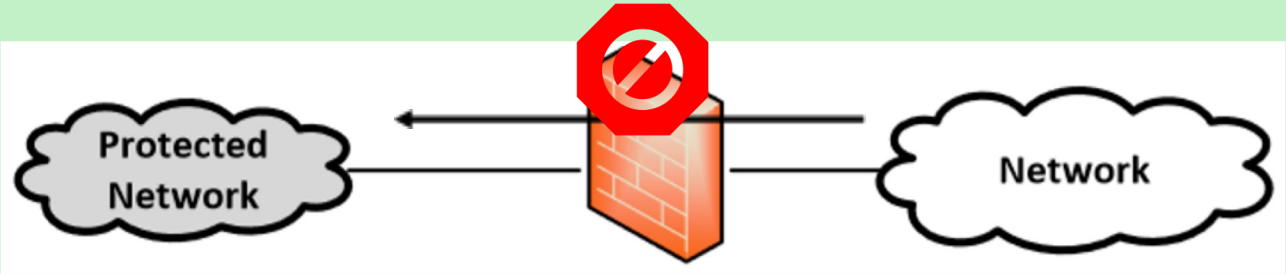
VPN – Virtual Private Network

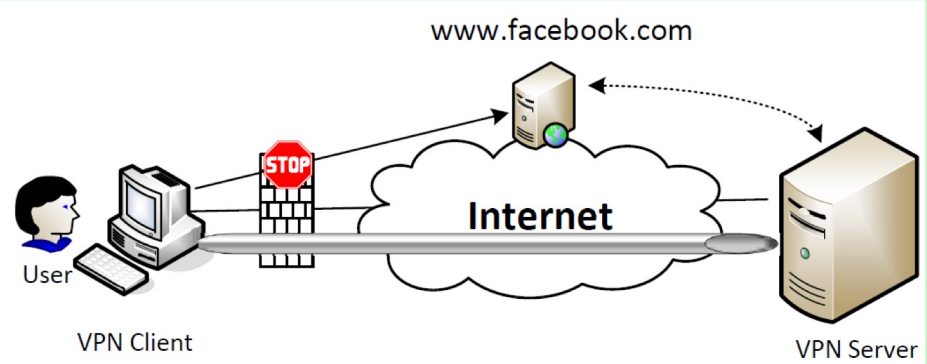
- What are the main use-cases of VPN?
- What properties of the CIA triad can VPN protect?
- In the following picture why can't client machine directly connect to machine V?
  - What's the job of the VPN server in this setup?



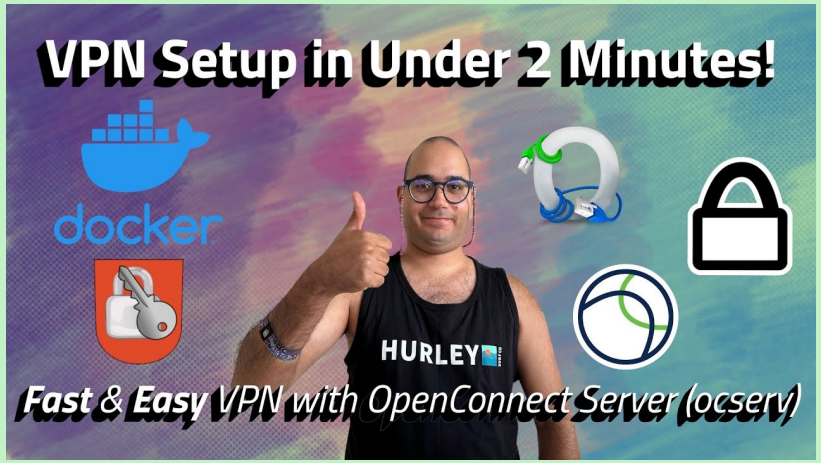
VPN – Other Applications

- VPN changes where traffic appears to be coming from. What are some use-cases of this?
- Imagine Facebook is blocked in your organization. Can we use VPN to bypass an egress firewall?





Some VPN Self Hosting Options



OpenVPN with ocserv

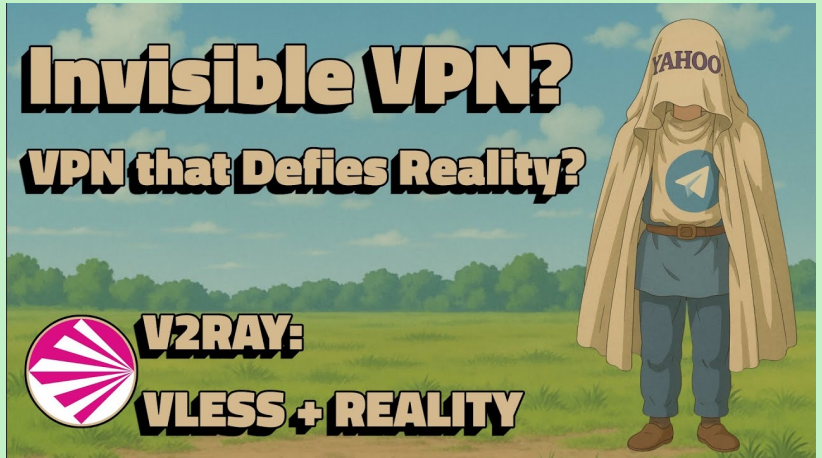
https://youtu.be/2VsZY1_EEQs?si=dVu_TVziJSP_cSBv

V2RAY: VLESS + REALITY

https://youtu.be/4TYffXhDYTo?si=gO2Mvy5J6fI2H-Qb

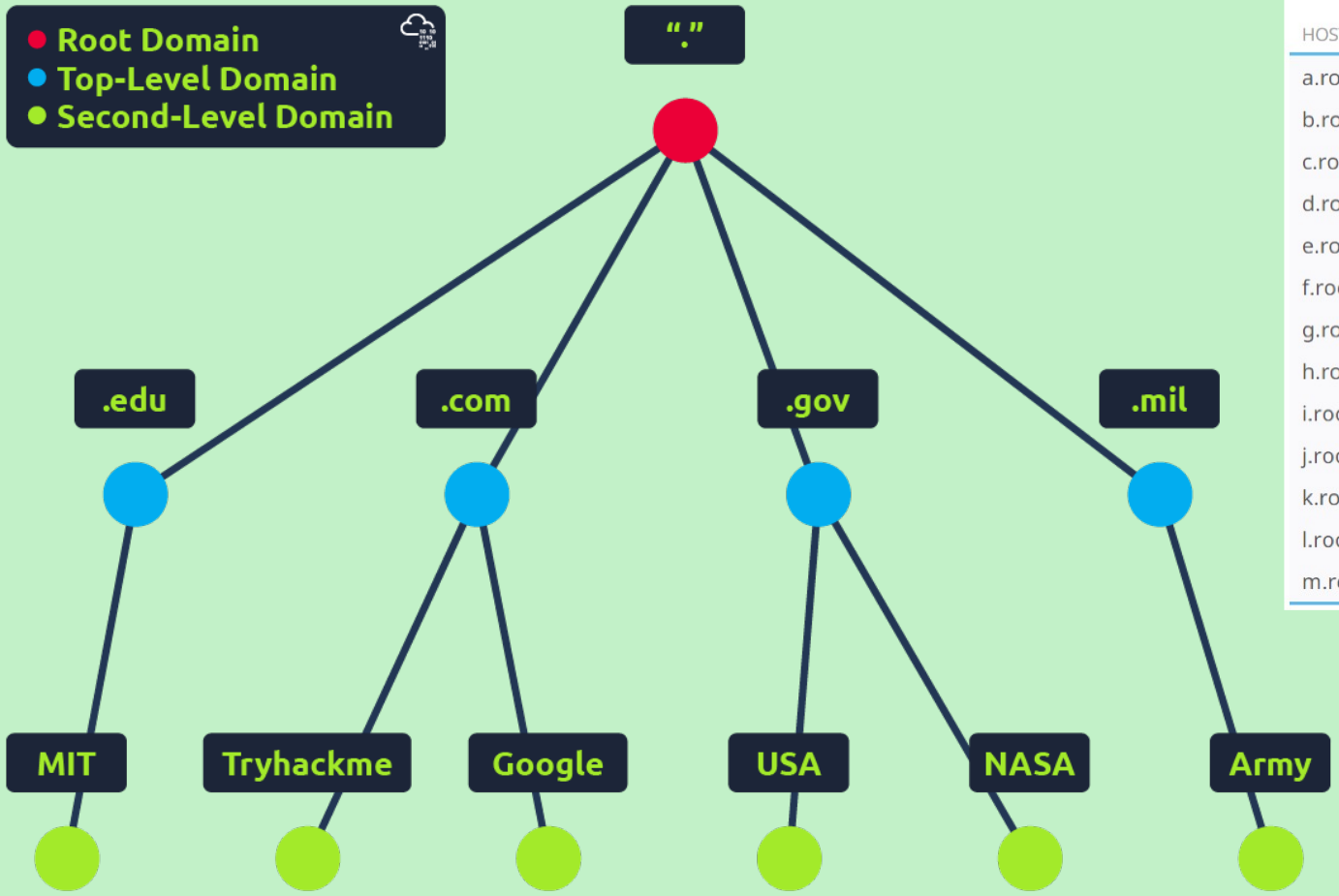
WireGuard w/o Traefik

https://youtu.be/Fvh9m4yldVI?si=iyR5W1G6BDvhLPLa



DNS Domain Hierarchy

13 Root nameservers host identical information

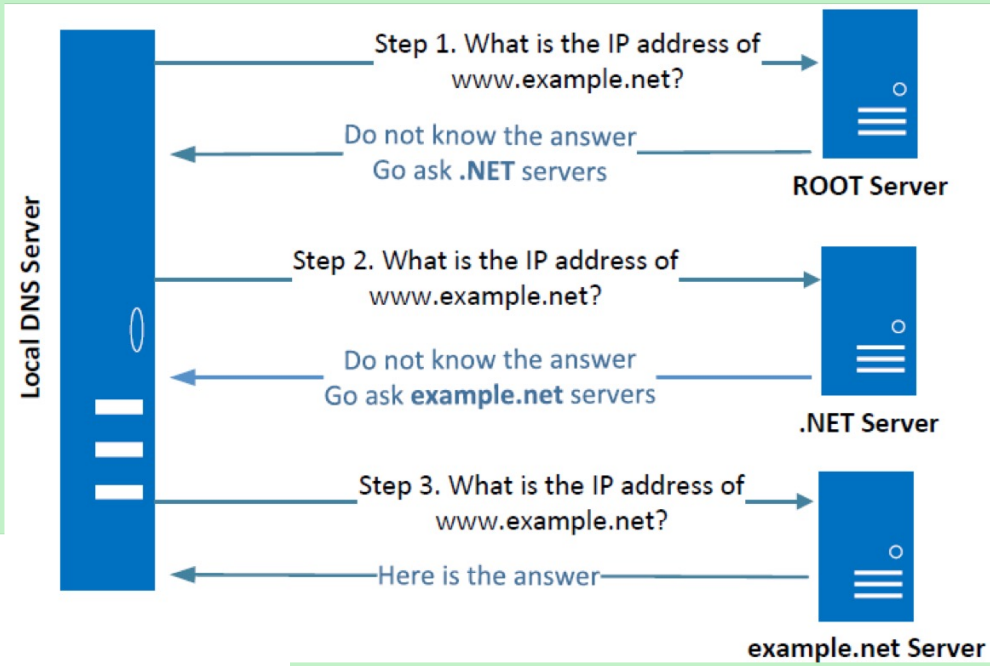


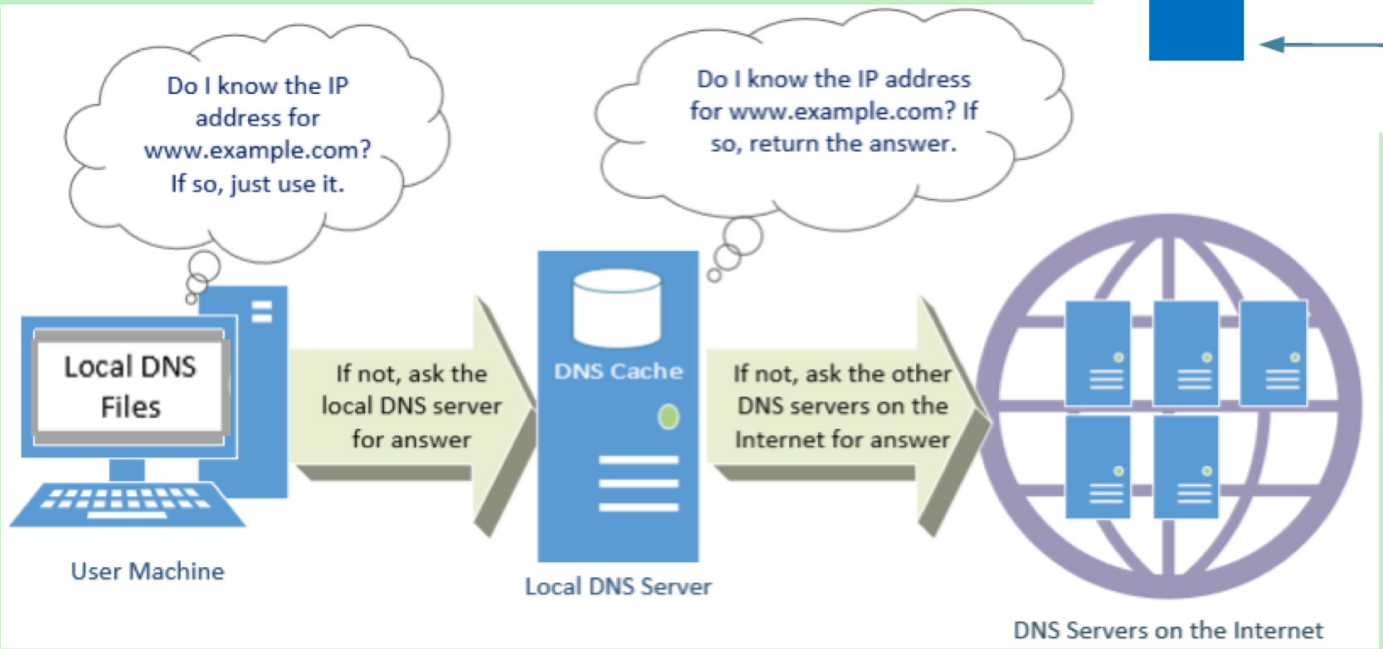
List of Root Servers

HOSTNAME	IP ADDRESSES	MANAGER
a.root-servers.net	198.41.0.4, 2001:503:ba3e::2:30	VeriSign, Inc.
b.root-servers.net	199.9.14.201, 2001:500:200::b	University of Southern California (ISI)
c.root-servers.net	192.33.4.12, 2001:500:2::c	Cogent Communications
d.root-servers.net	199.7.91.13, 2001:500:2d::d	University of Maryland
e.root-servers.net	192.203.230.10, 2001:500:a8::e	NASA (Ames Research Center)
f.root-servers.net	192.5.5.241, 2001:500:2f::f	Internet Systems Consortium, Inc.
g.root-servers.net	192.112.36.4, 2001:500:12::d0d	US Department of Defense (NIC)
h.root-servers.net	198.97.190.53, 2001:500:1::53	US Army (Research Lab)
i.root-servers.net	192.36.148.17, 2001:7fe::53	Netnod
j.root-servers.net	192.58.128.30, 2001:503:c27::2:30	VeriSign, Inc.
k.root-servers.net	193.0.14.129, 2001:7fd::1	RIPE NCC
l.root-servers.net	199.7.83.42, 2001:500:9f::42	ICANN
m.root-servers.net	202.12.27.33, 2001:dc3::35	WIDE Project

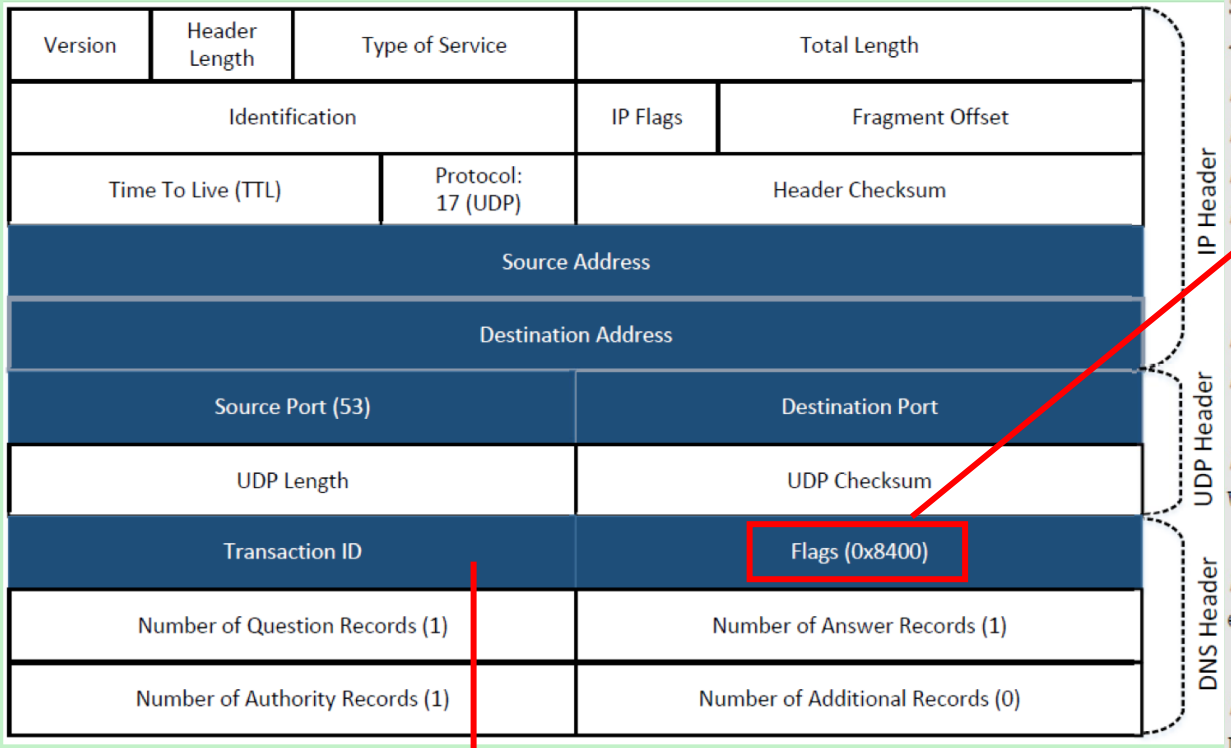
DNS Recursive Query Process

- What's the purpose of DNS cache on local DNS server?
- If user queries for www.example.com for the first time, what info will be saved in the cache?
- Will data remain in DNS cache forever?





DNS Query and Response




```
$ dig www.example.net
<<>> DiG 9.5.0b2 <<>> www.example.net
;; global options:  printcmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 27136
;; flags: qr aa rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 1,
    ADDITIONAL: 1

;; QUESTION SECTION:
;www.example.net.                IN      A

;; ANSWER SECTION:
www.example.net.        259200   IN      A       192.168.0.101

;; AUTHORITY SECTION:
example.net.            259200   IN      NS      ns.example.net.

;; ADDITIONAL SECTION:
ns.example.net.         259200   IN      A       192.168.0.10
```

CLASS Field

TYPE Field

Transaction ID is the same in a query and response

QR (Query/Response): Specifies if the message is a query (0) or response (1).
Opcode: Describes the query type (e.g., standard query, inverse query, or status request).
AA (Authoritative Answer): Indicates if the responding server is authoritative for the domain.
TC (Truncated): Set if the message was too large for UDP and needs TCP.
RD (Recursion Desired) & RA (Recursion Available): Control and signal recursive query capabilities.
Z: Reserved for future use, must always be 0.
RCODE: Response code indicating success, format error, server failure, etc.

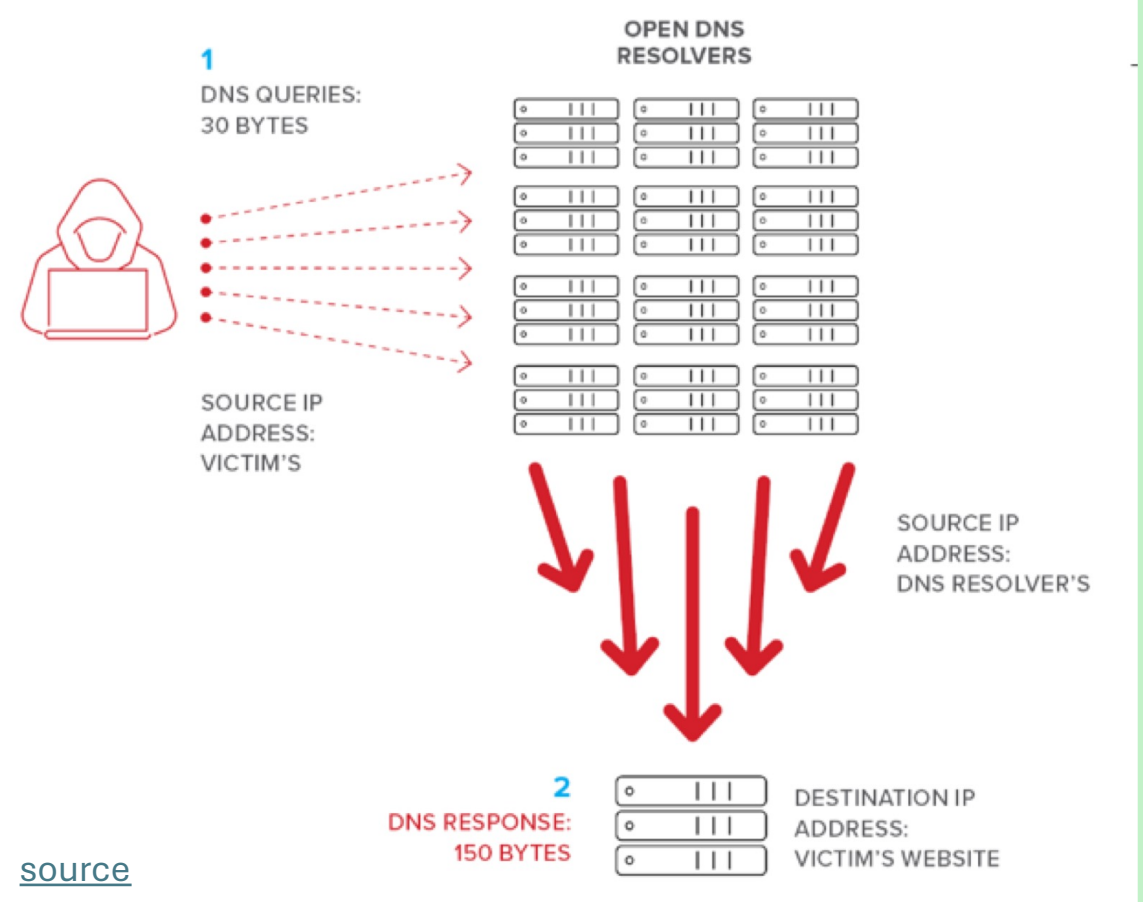
DNS Denial-of-Service Attacks

- Is it easy to launch a DoS attack against root nameservers?
- What about TLD Servers?
- DDoS attack on DNS provider Dyn

Each root server is typically a server farm consisting of many redundance computers to provide reliable services

DNS Amplification DoS Attack

- Is spoofing used in this attack?
- Why is it called amplification attack?

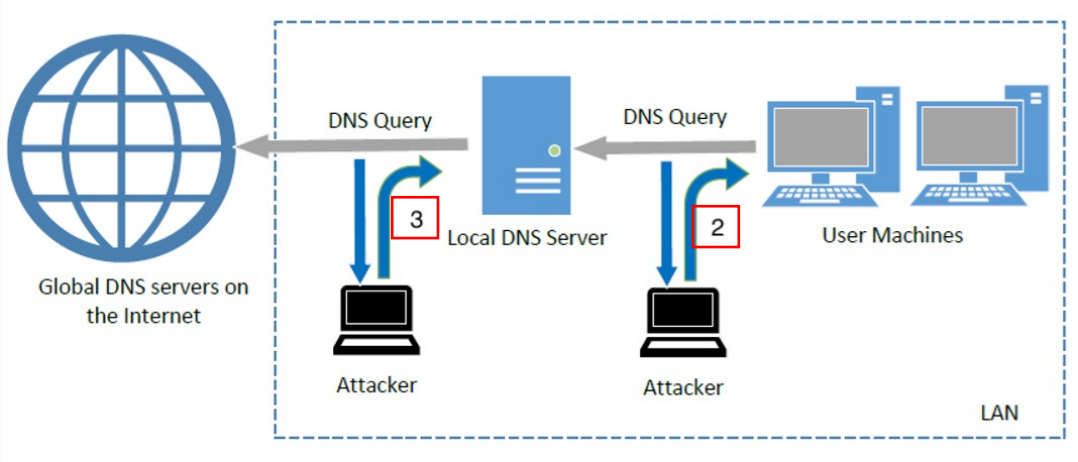


source

DNS Spoofing Attacks

(On same LAN as local DNS server)

- What is the primary goal of this kind of attack?
- Would a spoofing attack be more damaging at point 2 or 3?
  - Which one would result in DNS cache poisoning?
- What would be the source and destination IP in the spoofed packet in each attack?
- How can a spoofing attack hijacks all the requests to a specific domain (e.g. example.net)?

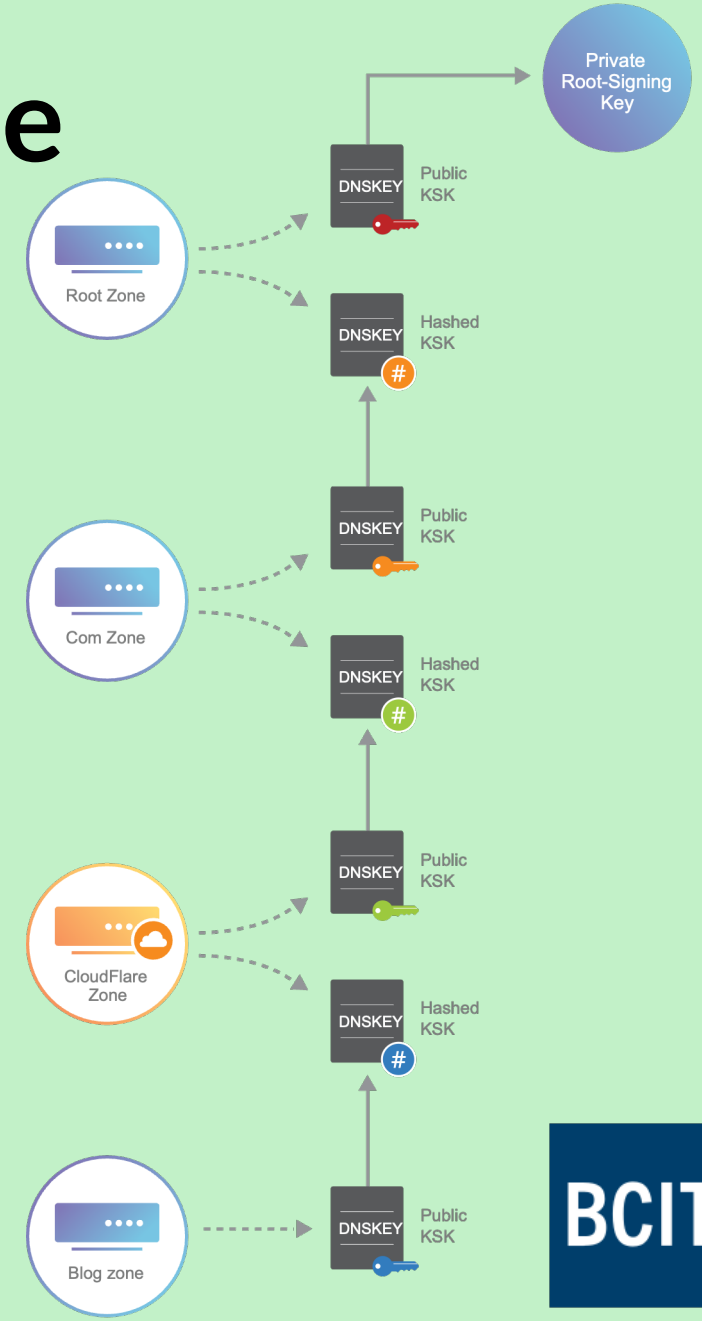



```
$ dig www.example.net
; <<>> DiG 9.10.3-P4-Ubuntu <<>> www.example.net
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 61991
;; flags: qr aa ra; QUERY: 1, ANSWER: 1, AUTHORITY: 1, ADDITIONAL: 0

;; QUESTION SECTION:
;www.example.net.    IN A

;; ANSWER SECTION:
www.example.net.    259200  IN A        1.2.3.4                ①

;; AUTHORITY SECTION:
example.net.        259200  IN NS       ns.attacker32.com.     ②
```

DNS Spoofing – Countermeasure

- DNSSEC
  - Each DNS record is digitally signed by the provider.
  - Public key is provided in the record.
  - Higher-level zones vouch for the public keys of lower-level zones
    - Chain of trust
- TLS/SSL
  - Owner of the IP (response from DNS) has to provide a signed digital certificate